

# 自作PCパーツECサイト 実装準備パッケージ

実装計画・47件のチケット・環境構築手順・AGENTS.md

レビュー版 0.9 / 2026年9月25日

この資料は実装開始前の計画である。製品コード、外部アカウント、デブロイ、課金設定は作成していない。LUNAは承認された1チケットずつ実装・検証する。

1. 実装計画
2. チケット一覧
3. 環境構築手順
4. AGENTS.md

# 実装計画

## 自作PCパーツECサイト 実装計画（レビュー版）

版 0.9 / 作成日 2026年9月25日 / 状態 実装前の計画。製品実装、外部アカウント作成、デプロイは未実施。

チケット本体 [docs/implementation-tickets.md](#) / 環境手順 [docs/environment-setup.md](#) / AIガードレール [AGENTS.md](#)

### 1. 正本と到達目標

要件の正本は[output/pdf/自作PCパーツECサイト\\_要件定義書\\_レビュー版.pdf](#)。基本設計は[output/pdf/自作PCパーツECサイト\\_基本設計書\\_レビュー版.pdf](#)、詳細設計は[output/pdf/自作PCパーツECサイト\\_詳細設計書\\_レビュー版.pdf](#)（編集原稿 [docs/detailed-design-review.md](#)）を継承する。送料940円、重量物の公式運賃加算、公開デモ個人情報の30日削除は詳細設計時に利用者が承認済みである。文書の古い「未決定」記載より、この承認済み内容を優先する。設計変更は実装担当が独断で行わない。

到達点は、公開ポートフォリオとして使える8カテゴリの模擬ECである。商品探索、基本5種の互換性、匿名カート、会員登録とGoogleログイン、模擬SMS、配送先、注文・在庫引当、Stripeテスト決済、注文履歴、管理、異常系、CI/CD、Vercel公開と運用を含む。実販売・実課金・実発送、利用者向け取り置き、ゲスト注文、構成保存は含まない。

### 2. 進め方と1チケットの完了条件

LUNAはチケットIDを1件だけ受け取り、依存を確認してから作業する。原則として1チケット=1レビュー可能な変更単位とし、コード・SQL・テスト・ドキュメントを同時に完結させる。外部設定が必要なチケットは、利用者作業が終わるまでローカル実装と模擬試験だけ進め、接続確認を未完了として明示する。番号は参照IDであり、依存により一部は番号順と異なる。

共通の完了条件は、①目的と対象範囲に一致、②受け入れ条件を満たす、③チケット指定テストと関連回帰テストが成功、④秘密・個人情報がログやGitに出ない、⑤設計差分と未解決事項を報告、⑥レビュー可能な変更単位であること。テストを弱めたり異常系を削ったりして合格にしない。

### 3. 実装の順序とゲート

#### ● M0 契約と土台

チケット: T01-T05 / 終了時に確認すること: ローカルGit・アプリ雛形、ワイヤー、OpenAPI、Zod基礎、CI基礎。外部接続なしでレビュー可能。

#### ● M1 データと権限

チケット: T06-T11 / 終了時に確認すること: SQLマイグレーション、RLS、Storage権限、初期テストデータ、競合試験の土台。

#### ● M2 公開カタログ

チケット: T12-T16 / 終了時に確認すること: UIトークン、検索、カテゴリ・詳細、各画面の空・エラー状態。

#### ● M3 認証と会員

チケット: T17-T21 / 終了時に確認すること: Supabase Auth、Google、メール、模擬SMS、配送先。T22の削除は決済処理後に実施。

#### ● M4 構成とカート

チケット: T23-T27 / 終了時に確認すること: 5種の互換性、匿名/会員カート、送料計算器、構成UI、概算送料。T27はT26の前に実施。

#### ● M5 金額と購入

チケット: T28-T35、T22 / 終了時に確認すること: 正式見積、原子的在庫引当、Stripeテスト決済、Webhook、期限処理、30日削除、履歴、通知。

#### ● M6 管理

チケット: T36-T41 / 終了時に確認すること: 管理権限、商品・在庫・注文・送料・SMTP設定。

#### ● M7 品質と公開

チケット: T42-T47 / 終了時に確認すること: デモ異常系、レスポンス・アクセシビリティ、セキュリティ・RLS、E2E、CI/CD、公開・運用。

着手の推奨順序は、[T01-T18](#) → [T20](#) → [T19](#) → [T21](#) → [T23](#) → [T25](#) → [T27](#) → [T24](#) → [T26](#) → [T28-T34](#) → [T22](#) → [T35-T47](#)である。T01-T05は製品実装の先行作業として固定する。依存関係の詳細はチケット本体を正とする。Vercel、Supabase、Google、Stripe、SMTP等の外部作業は対応するチケットの直前に提示する。外部サービスの有料契約を前提とする作業は、名称・見積・代替案を示して利用者確認後に進める。

## 4. 実装前に固定する技術上の選択

設計で選択肢として残った範囲を、仕様を変えない形で次のように固定する。アプリは単一のNext.jsプロジェクト、`src/app`をルートとする。商品検索は初期版ではPostgresの構造化条件と`pg_trgm`による名前・メーカー検索を使う。構成選択は共有可能なURLクエリに持ち、保存はしない。Supabaseの権限付けはRLSと限定されたDB関数、SMTP秘密はSupabase Vaultの保護参照を第一候補とし、実際の利用可能性をT20/T41で確認する。Stripe Checkoutはホスト型画面を使う。GitHub Actionsは検証、Vercel Git連携はアプリのデプロイを担当し、二重デプロイを避ける。Supabase PreviewとProductionは別プロジェクトを使い、PRごとのSupabase Branchingは前提にしない。

技術選択がサービス仕様・金銭・個人情報・セキュリティを変えると判明した場合は決定を停止し、影響を報告する。上記の検索・構成状態・Vaultは実装チケットで検証する技術案であり、可なら同等の保護と振る舞いを満たす案をレビューに出す。

## 5. GitHubとディレクトリの初期構成

T01で既存の設計資料を保持してGitリポジトリを初期化する計画である。`main`を公開用、`feature/Txx-*`を作業用とし、PRでレビューする。`.gitignore`は`.env*`の実値、Supabase CLI一時ファイル、テスト結果、ビルド成果物を除外するが、`.env.example`は追跡する。`README.md`にはデモの非販売説明、設計資料、ローカル起動、テスト、外部設定の必要性を記す。`AGENTS.md`と設計資料を同じリポジトリで版管理する。T05で`.github/workflows/ci.yml`を追加し、後にT46でDB適用・デプロイ運用を組み込む。

予定構成は`src/app/(shop)`、`src/app/admin`、`src/app/api`、`src/components`、`src/styles`、`src/features`、`src/server`、`src/lib`、`supabase/migrations`、`supabase/seed.sql`、`tests/unit`、`tests/integration`、`tests/e2e`、`docs/api`、`docs/wireframes`。ディレクトリ責務は`AGENTS.md`に従う。まだディレクトリや製品コードは作らない。

## 6. 設計成果物を作るタイミング

### ● PC/タブレット/スマートフォンの画面ワイヤー

**主担当チケット:** T02 / **完了条件:** S01-S17、A01-A06の主要導線・異常状態を示し、詳細設計の色とブレイクポイントに対応する。

### ● Zodスキーマ

**主担当チケット:** T04、各APIチケット / **完了条件:** 共通の入力・応答・エラー契約を定義し、サーバー側で必ず再検証する。

### ● SQLマイグレーション

**主担当チケット:** T06-T08、以降のDB変更チケット / **完了条件:** 詳細設計の型・制約・索引・状態遷移に対応し、ローカル再構築できる。

### ● RLSポリシーSQL

**主担当チケット:** T09-T10 / **完了条件:** 匿名・会員A/B・管理者の許可／拒否試験を持つ。

### ● OpenAPI

**主担当チケット:** T03、各APIチケット / **完了条件:** 入出力・認証・エラーが実装と一致し、差分がPRで確認できる。

### ● テストデータ定義

**主担当チケット:** T11 / **完了条件:** 互換／不一致／不明、在庫切れ／競合、送料・税境界、Stripe成功／失敗を再現できる。実個人情報を含まない。

## 7. レビュー・リリース判定

PRでは要件IDとチケットID、変更範囲、受け入れ条件、テスト結果、画面差分、DB/RLS影響、環境変数変更、データ移行・復旧方法を記載する。M5終了時に購入の正常系・異常系を通し、M7でPC/タブレット/スマホ・権限・金額・競合・Webhook・削除を再確認する。公開は、Stripeライブ鍵不在、実SMS不送信、Preview/Production分離、個人情報30日削除、規約表示、料金出典、バックアップ保持条件の確認後とする。

## 8. 進行を止めるべき条件

- 正本間の矛盾、料金・個人情報・認証・在庫・公開範囲の仕様変更が必要。
- 外部サービスが有料契約を要求する、または無料枠で設計の保護条件を満たせない。
- Supabaseのバックアップを含め30日個人情報削除を保証できない。
- PreviewとProductionのDB、SMTP送信先、Stripeテストデータ、秘密が分離できない。
- CIまたはRLS・金額・在庫の重要テストが失敗している。

これらは該当するチケットの作業を止め、具体的な状況と選択肢を利用者に報告する。無関係なローカル作業は続けてよい。

## 9. 公式手順への参照

- [Vercel Git連携、環境変数](#)
- [Supabase CLIのローカル開発、DBマイグレーション、環境管理](#)
- [Supabase Auth Redirect URL、Googleログイン、Send Email Hook](#)
- [GitHub Actionsの環境、ワークフロー構文](#)

# チケット一覧

## 自作PCパーツECサイト 実装チケット一覧（レビュー版）

版 0.9 / 作成日 2026年9月25日 / 状態 未着手。LUNAは1件ずつ実装・検証する。

**順序** 実際の着手順は[docs/implementation-plan.md](#)第3章の順序表を正とする。番号は参照IDであり、依存を越えて着手しない。外部設定が必要なら利用者作業を確認してから接続試験を行う。

**共通完了条件** [docs/implementation-plan.md](#)第2章と[AGENTS.md](#)を適用する。受け入れ条件の「表示」はPC・スマホで確認する。

## M0 契約と土台

### T01 GitHub向けリポジトリとローカル雛形

- **目的**：設計資料と製品コードを追跡できる土台を作る。
- **内容・範囲**：既存資料を保全し、Git初期化、[main](#)、README、[.gitignore](#)、[.env.example](#)、Next.js/TypeScript/CSS Modulesの最小雛形、予定ディレクトリを用意。GitHubへの接続は利用者のリポジトリ作成・認証後。
- **依存**：なし。外部ゲートG-GitHub。
- **受け入れ条件**：秘密を追跡せず、起動・型検査が通り、資料へのリンクと非販売の説明がある。既存PDFを消さない。
- **テスト**：ローカル起動、型検査、Git追跡対象と秘密除外の確認。

### T02 画面ワイヤーと遷移レビュー

- **目的**：製品UI着手前にS01-S17、A01-A06の構造を固定する。
- **内容・範囲**：[docs/wireframes/](#)にPC・タブレット・スマホの主要画面、ヘッダー、検索、構成、カート、注文、認証、管理、警告・空・エラー状態と遷移を作る。デザインルールを添える。
- **依存**：T01。
- **受け入れ条件**：詳細設計の全画面IDと主要異常状態が追跡でき、0-767/768-1199/1200px以上の変化が分かる。互換性不一致でも購入導線が残る。
- **テスト**：設計画面一覧との対応表、キーボード操作・文言・320pxレイアウトのレビュー。

### T03 OpenAPI初版とAPI責務表

- **目的**：画面とサーバーの契約を先に明示する。
- **内容・範囲**：[docs/api/openapi.yaml](#)に詳細設計第6章の経路、認証方式、入出力、共通エラー、幕等キー、Webhook生ボディを記載。Server Componentの直接取得はAPI扱いにしない。
- **依存**：T02。
- **受け入れ条件**：全主要経路に成功・主要失敗応答と権限があり、画面ワイヤーの操作と対応する。
- **テスト**：OpenAPI lint・参照解決、画面操作との手動照合。

### T04 共通Zodスキーマとエラー型

- **目的**：入力・応答形式を一箇所で管理する。
- **内容・範囲**：共通ID、円額、数量、検索クエリ、住所、API成功/失敗、状態列挙のZodスキーマと型を作る。秘密やDBエラーの応答漏出を防ぐ。
- **依存**：T03。
- **受け入れ条件**：OpenAPIと矛盾せず、サーバー再検証のために利用できる。未使用の推測フィールドを増やさない。
- **テスト**：Vitestで正常・境界・不正値、OpenAPI契約との差分確認。

### T05 CIの最小ゲート

- **目的**：以後のチケットが同じ品質チェックを通るようにする。

- **内容・範囲** : GitHub ActionsでPR・mainのlint、型検査、Vitest、OpenAPI lint、ビルドを実行。Node/依存を固定しキャッシュする。外部秘密を使わない。
- **依存** : T01、T03、T04。外部ゲートG-GitHubは実行時のみ。
- **受け入れ条件** : PRで成功・失敗が可視化され、秘密を必要とするテストをPRの未信頼コードへ渡さない。
- **テスト** : ローカル同等コマンド、意図的な型エラーでCI失敗の確認。

## M1 データと権限

### T06 会員・商品スキーマSQL

- **目的** : 会員補助情報と8カテゴリの商品を型付きで保持する。
- **内容・範囲** : [profiles](#)、[admin\\_memberships](#)、[addresses](#)、[categories](#)、[products](#)、用途・画像、8仕様表をマイグレーション化。制約、FK、索引、公開時必須値検証を含む。
- **依存** : T01、T04。
- **受け入れ条件** : 詳細設計第4.1/4.2章と一致し、仕様不足商品は下書き・テストデータとして表現できる。商品カテゴリと仕様表の不一致を拒否する。
- **テスト** : Supabaseローカルdb [reset](#)、DB制約・索引・FKの統合テスト。

### T07 在庫・注文・決済スキーマSQL

- **目的** : 金額・在庫・決済履歴を独立した状態で保持する。
- **内容・範囲** : [inventory](#)、[stock\\_allocations](#)、[carts](#)、明細、[orders](#)、明細スナップショット、[payment\\_attempts/events](#)、在庫調整ログをマイグレーション化。
- **依存** : T06。
- **受け入れ条件** : [allocated<=on\\_hand](#)、試行一意性、商品削除後の注文履歴、金額非負・合計整合の制約がある。
- **テスト** : ローカル再構築、重複・負数・不正遷移用DB試験。

### T08 設定・通知・監査スキーマSQL

- **目的** : 送料・SMTP・認証補助・監査を分離して保存する。
- **内容・範囲** : [sms\\_challenges](#)、[shipping\\_settings](#)、[smtp\\_settings](#)、[notification\\_jobs](#)、[audit\\_logs](#)、保護秘密参照のマイグレーション。送料初期値940円、閾値1万円、重量物20kg、東京都発送。
- **依存** : T06、T07。
- **受け入れ条件** : 秘密平文・OTP平文を表に保存せず、設定版を注文へ参照でき、監査ログが追記専用。
- **テスト** : 制約・一意索引・秘密非露出・ローカル再構築。

### T09 公開データ・StorageのRLS SQL

- **目的** : 公開商品だけを安全に閲覧させる。
- **内容・範囲** : カテゴリ、商品、仕様、画像、可用在庫投影のRLS・GRANT・Storageポリシー。下書きと非公開は匿名に見せない。
- **依存** : T06、T07。
- **受け入れ条件** : [anon](#)と会員は公開商品の必要情報だけ読め、商品・画像・在庫を直接変更できない。
- **テスト** : 匿名／会員A/B／管理者でSELECT・INSERT・UPDATE・DELETEの許可拒否、Storage URL試験。

### T10 本人・管理者のRLS SQL

- **目的** : 配送先、カート、注文、決済、設定を権限で分離する。
- **内容・範囲** : 本人所有ポリシー、注文に従属する明細・試行、管理者判定関数、非公開スキーマ、限定DB関数の実行権限、既定GRANT剥奪。
- **依存** : T07-T09。
- **受け入れ条件** : 会員Aから会員Bを読書きできず、自己管理者昇格不可。サービスロール経路は明示されたサーバー処理だけ。

- **テスト** : RLS許可拒否マトリクス、`auth.uid()=null`、関数`search_path`、関連明細のID推測試験。

## T11 テストデータ定義と投入

- **目的** : 要求された正常・異常系を再現可能にする。
- **内容・範囲** : `supabase/seed.sql`等に8カテゴリ、互換・不一致・判定不能、売切れ、残数1、9,999/10,000円、20kg境界、料金表のテスト版を定義。実在製品を参考にしても画像・価格の出典を記録し、外部ECから自動取得しない。
- **依存** : T06–T10。
- **受け入れ条件** : ケース表から商品IDと期待結果を追跡でき、実メール・住所・電話番号などの個人情報を含まない。
- **テスト** : ローカル再投入の冪等性、データ件数・各ケースの検出試験。

## M2 公開カタログ

### T12 デザイントークンと共通シェル

- **目的** : 専門ECとして一貫した視覚基盤を作る。
- **内容・範囲** : 詳細設計の配色、文字、余白、ヘッダー、フッター、検索導線、パンくず、ボタン、フォーム、状態表示、スケルトンをCSS Modulesで実装。
- **依存** : T02、T01。
- **受け入れ条件** : 購入前に非販売・非課金・非発送を示し、色だけに依存しない状態表示、44px操作領域を備える。
- **テスト** : Vitestの部品試験、Playwrightのキーボード・320px・200%拡大確認。

### T13 商品検索サービス/API

- **目的** : 初心者の用途別探索と経験者の仕様絞り込みを可能にする。
- **内容・範囲** : 公開商品に限定したキーワード・カテゴリ・用途・メーカー・価格・カテゴリ仕様のAND検索、安定ソート、24件ページング、`GET /api/products`。OpenAPIとZodを更新。
- **依存** : T09、T11、T03、T04。
- **受け入れ条件** : URL条件が再現可能で、下書きは漏れず、0件と不正条件を区別する。
- **テスト** : Vitest条件組合せ、DB検索・ソート・ページ境界、RLS下書き漏出試験。

### T14 トップ・カテゴリ・検索画面

- **目的** : S01–S03の探索を完結させる。
- **内容・範囲** : 用途別入口、8カテゴリ、検索欄、絞り込み、並べ替え、0件・読み失敗・条件解除。PCの左フィルタとスマホの開閉パネル。
- **依存** : T12、T13。
- **受け入れ条件** : 初心者は用途から、経験者は直接条件指定から商品へ進める。URL更新と戻る操作で条件が保持される。
- **テスト** : PlaywrightでPC・スマホの探索、空状態、キーボード操作。

### T15 商品詳細・画像配信

- **目的** : S04で購入判断に必要な情報を示す。
- **内容・範囲** : 公開商品の画像・説明・型番・仕様・税込価格・可用状態、数量入力、カート／構成への導線。公開画像への配信経路を実装。
- **依存** : T09、T12–T14。
- **受け入れ条件** : 非公開商品404、売切れは追加不可、仕様名は検索と一致、画像代替テキストを持つ。
- **テスト** : Playwrightで公開・非公開・売切れ、画像アクセスのRLS試験。

### T16 カタログ例外と初期データ検収

- **目的** : 商品系の想定外の表示や仕様不足を整理する。
- **内容・範囲** : 管理側の下書き、空カテゴリ、仕様欠損、画像欠損、価格変更、公開切替後の検索結果を画面とデータで検証し、必要な文言・回復導線を整える。

- **依存** : T13–T15。
- **受け入れ条件** : 各状態の原因と次の操作が分かり、非公開データが公開画面へ漏れない。
- **テスト** : Vitest/Playwrightの異常系、RLS回帰。

## M3 認証と会員

### T17 Supabase SSRとメール・パスワード認証

- **目的** : 会員本人のセッションとメール確認を成立させる。
- **内容・範囲** : @supabase/ssr、S07/S08/S09のメール登録・確認・ログイン・ログアウト、セッション更新、同一サイト内戻り先、Production認証省略拒否。
- **依存** : T06、T10、T12。外部ゲートG-Supabaseは接続時。
- **受け入れ条件** : 未確認会員は購入不可、通常ログインにSMSなし、他人セッション不可、Productionで省略設定を有効化できない。
- **テスト** : Vitest認証分岐、Playwright登録・ログイン、RLS本人/他人、Production設定失敗試験。

### T18 Google OAuth

- **目的** : Googleで登録・ログインできるようにする。
- **内容・範囲** : Supabase Auth Google Provider、OAuth callback、最小スコープ、戻り先検査、配送先不足案内。GoogleトークンをアプリDBに保存しない。
- **依存** : T17。外部ゲートG-Googleで利用者がOAuthクライアントと許可URLを設定。
- **受け入れ条件** : GoogleログインにSMSなし、会員識別が安定し、意図しない外部URLへリダイレクトしない。
- **テスト** : OAuthフローのテスト環境接続、callback失敗・戻り先拒否、アカウント分離。

### T19 模擬SMSと再設定のOTP

- **目的** : 公開デモで6桁コードの発行・入力・照合を実現する。
- **内容・範囲** : 登録・パスワード再設定のフロー、コードハッシュ、10分期限、5回試行、60秒再送制限、当該フロー内デモ通知。Development/Test限定の実SMS差替え境界と省略機能を分離。
- **依存** : T08、T17、T20。
- **受け入れ条件** : 公開デモで電話番号を収集・実送信せず、誤り・期限切れを拒否。通常・GoogleログインにはOTPを要求しない。
- **テスト** : Vitest境界・制限、Playwright登録/再設定、Production省略不可。実端末SMS試験は別ゲートで検証後のみ記録。

### T20 Supabase Send Email HookとSMTP送信

- **目的** : 会員確認・再設定・注文通知のメール送信経路を作る。
- **内容・範囲** : 署名付きAuth Hook、許可テンプレート、SMTPアダプタ、送信失敗・再送、設定の保護参照、環境別送信先制限。秘密の管理UIはT41。
- **依存** : T08、T17。外部ゲートG-SMTPで利用者が送信先と資格情報を用意。
- **受け入れ条件** : 署名不正を拒否し、秘密をログ・画面に出さず、送信障害時は認証を完了扱いにしない。
- **テスト** : Hook署名・テンプレート・SMTP失敗の統合試験、許可されたテスト宛先への実送信確認。

### T21 配送先と会員画面

- **目的** : 注文前に本人の国内配送先を管理できるようにする。
- **内容・範囲** : S11/S15、住所CRUD・既定住所、郵便番号・都道府県・文字数検証、架空データ案内、注文復帰。OpenAPI/Zodを同期。
- **依存** : T10、T12、T17。
- **受け入れ条件** : 本人だけ読み書きでき、住所なし・入力エラー・削除確認が明確。Google会員も本サイト側で入力する。
- **テスト** : Vitest住所検証、Playwright登録/編集/削除、会員A/BのRLS拒否。

## T22 アカウント削除と30日消去

- **目的**：公開デモの個人情報方針を動作で満たす。
- **内容・範囲**：再認証済み削除、住所・カート・注文・通知・Authアカウントの消去、15分間隔の期限ジョブ、決済中の照合、失敗時の幂等再実行、バックアップ条件の運用確認。
- **依存**：T17、T21、T31、T32、T34。番号上はM3だが、購入・期限・通知処理を終えた後に着手する。
- **受け入れ条件**：本人による即時削除と30日期限で個人情報が消え、他人のデータは削除されず、失敗は監視される。
- **テスト**：DB/Playwright削除、30日境界、途中失敗・再実行、削除後RLS、バックアップ保持条件。

## M4 構成とカート

### T23 互換性判定エンジン/API

- **目的**：5組の比較を一貫した結果で返す。
- **内容・範囲**：CPU/MB Socket、MB/メモリDDR、MB/ケース形状、GPU/ケース長、クーラー/CPU Socketの [compatible/incompatible/unknown/not\\_applicable](#)、理由・比較値・適合一覧URL。OpenAPI/Zodを同期。
- **依存**：T06、T09、T11、T13。
- **受け入れ条件**：仕様欠損を一致としない。不一致でも購入可の情報として返し、非公開商品IDは拒否する。
- **テスト**：Vitestで5判定×一致/不一致/欠損、APIの権限・リンク・不正ID。

### T24 構成確認UI

- **目的**：初心者が組合せを理解して適合商品へ移動できるようにする。
- **内容・範囲**：S05、8カテゴリ選択、URL共有可能な一時状態、比較値・理由・欠損・適合候補リンク、カート追加。
- **依存**：T12、T15、T23、T25。
- **受け入れ条件**：不一致の理由が具体的で購入を妨げず、繰り返しモーダルなし。欠損は断定しない。
- **テスト**：Playwrightで一致/不一致/不明、適合一覧遷移、スマホ表示。

### T25 匿名・会員カートのサーバー処理

- **目的**：購入前の商品選択を安全に保存する。
- **内容・範囲**：署名付きHttpOnly匿名Cookie、会員カート、追加・数量・削除・ログイン時統合、価格・販売可能数再取得、売切れ409。OpenAPI/Zodを同期。
- **依存**：T07、T10、T15、T17。
- **受け入れ条件**：他人カートを読めず、数量1-10、価格を固定しない。統合時の超過を利用者へ知らせる。
- **テスト**：Vitest数量/統合、RLS・Cookie改ざん、API競合/売切れ。

### T26 カートUIと概算送料

- **目的**：S06で現在の内容と送料の不確実性を示す。
- **内容・範囲**：明細編集、削除、商品小計、送料「概算」、変更・売切れ・空状態、ログイン導線。概算は確定額として決済へ渡さない。
- **依存**：T12、T25、T27。
- **受け入れ条件**：利用者に概算と正式金額の違いが分かり、在庫不足から数量変更できる。
- **テスト**：Playwrightで匿名/会員、空・売切れ・価格変更、PC/スマホ。

## M5 金額と購入

### T27 送料・税計算器

- **目的**：注文金額をサーバーで一意に確定する。
- **内容・範囲**：税込円整数、通常送料940円、商品小計1万円以上の通常無料、20kg以上の商品ごとのヤマト公式運賃、離島加算なし、標準税率10%の内税一回切り捨て。料金表版・根拠URL・東京都初期発送元を扱う。

- **依存** : T08、T11、T04。
- **受け入れ条件** : 住所・梱包・料金表欠損、ヤマト上限超過は金額を仮定せず決済不可。カート用概算と注文用正式見積を区別する。
- **テスト** : Vitestで9,999/10,000円、19,999/20,000g、北海道・沖縄・離島、複数重量物、税端数、設定版変更。

## T28 住所選択・正式見積・注文確認

- **目的** : 支払い前に最終金額と互換性を確認させる。
- **内容・範囲** : [POST /api/checkout/quote](#)、S12/S13、配送先、商品現在価格・在庫、送料内訳、内税額、見積期限、互換性警告、差額再確認。OpenAPI/Zodを同期。
- **依存** : T21、T23、T25、T27。
- **受け入れ条件** : ブラウザ送信額を採用せず、送料算定不能・在庫不足・価格変更を説明して支払いへ進ませない。不一致だけでは支払いを止めない。
- **テスト** : Vitest見積、API価格改ざん・409/503、Playwright住所なし・警告・差額。

## T29 原子的な注文作成・在庫引当

- **目的** : 同時注文でも在庫超過と二重注文を防ぐ。
- **内容・範囲** : 商品ID順の行ロック、可用数検証、注文・明細・スナップショット・引当・試行の単一DBトランザクション、30分期限、同一checkout keyの幂等処理。
- **依存** : T07、T10、T27、T28。
- **受け入れ条件** : 残数1に同時2注文でも1件だけ引当、失敗時全ロールバック、価格・住所・送料版が注文に固定される。
- **テスト** : DB統合の並列注文、デッドロック・ロールバック、幂等再送、スナップショット確認。

## T30 Stripe CheckoutテストSession

- **目的** : 実課金なしで決済成功・失敗を体験させる。
- **内容・範囲** : [POST /api/checkout/start](#)、Stripe CheckoutテストSession、JPY額・注文IDメタデータ・期限・Idempotency-Key、Session保存、作成失敗時の引当解放。カード情報はサイトで受け取らない。
- **依存** : T29。外部ゲートG-Stripeで利用者がテストアカウント・テスト鍵を用意。
- **受け入れ条件** : 注文額とStripe額が一致し、同じ操作の再送で別注文を作らない。ライブ鍵を拒否する。
- **テスト** : Stripeテスト環境、SDK失敗・タイムアウト・DB応答不明の統合試験。

## T31 Stripe Webhookと決済状態

- **目的** : 署名済み通知を唯一の自動成功根拠にする。
- **内容・範囲** : 生ボディ署名検証、イベントID重複排除、Session/PaymentIntent照合、金額・通貨・注文ID検査、成功時の在庫消費、失敗時の引当解放をDBトランザクション化。
- **依存** : T29、T30。
- **受け入れ条件** : 戻りURLだけで成功にせず、重複・逆順・偽署名・金額不一致に安全に対応する。DB失敗時は再送で回復できる。
- **テスト** : Stripe CLI/テストイベント、偽署名、同一イベント2回、逆順、異額、DB障害・再送。

## T32 期限切れ照合と補償ジョブ

- **目的** : 未完了の引当を安全に回収する。
- **内容・範囲** : Supabase Cron→署名付きVercel内部API→Stripe現在状態照合、期限切れ解放、照合不能の[review\\_required](#)、遅延成功と再試行の整合処理。
- **依存** : T31。外部ゲートG-Supabase/G-StripeでCron・API秘密の接続設定。
- **受け入れ条件** : 30分経過だけで無条件解放せず、二重販売を起こさない。遅延成功の矛盾は管理者確認に送る。
- **テスト** : Vitest状態機械、DB統合の期限・遅延・重複、Cron再実行・外部障害。

## T33 決済結果・注文履歴画面

- **目的** : 利用者に注文結果と次の操作を示す。

- **内容・範囲**：S14/S16/S17、サーバー状態取得、確認中・成功・失敗・期限切れ・要確認、スナップショット表示、再試行導線。カート整理は成功確定後。
- **依存**：T31、T32、T12、T17。
- **受け入れ条件**：Webhook未着なら確認中、失敗を完了と表示しない。他人の注文IDは404相当。
- **テスト**：Playwright成功/失敗/保留、RLS他人注文、過去商品・住所変更後の履歴。

### T34 注文・認証通知のジョブ

- **目的**：送信失敗が注文状態を壊さない通知を実現する。
- **内容・範囲**：[paid](#)後の注文完了メール一回投入、再試行・失敗監視、認証メールとのテンプレート区分、宛先制限。個人情報ジョブログへ残さない。
- **依存**：T20、T31、T08。
- **受け入れ条件**：決済Webhook重複でも重複メールを送らず、通知失敗で[paid](#)を戻さない。
- **テスト**：ジョブ幂等・再試行、SMTP障害、テンプレートと秘密非露出。

### T35 注文系の統合検収

- **目的**：M5の正常系・異常系を通して確認する。
- **内容・範囲**：商品探索→カート→住所→見積→テスト決済→結果→履歴をデータセットで通し、在庫競合・失敗・期限切れ・互換性警告を再確認。
- **依存**：T26、T28-T34。
- **受け入れ条件**：金額・在庫・注文・決済の表示とDB状態が一致し、原因と次の操作を表示する。
- **テスト**：Playwright主要導線、DB状態照合、Webhook再送、全関連Vitest/RLS回帰。

## M6 管理

### T36 管理者判定と管理画面シェル

- **目的**：一般会員と管理者の操作領域を分離する。
- **内容・範囲**：A01、管理ナビ、管理API共通認可、権限付与の手動運用手順、監査ID。管理者権限の自己付与UIは作らない。
- **依存**：T10、T12、T17。
- **受け入れ条件**：非管理者のURL直打ち・API呼出しを拒否し、秘密や個人情報をダッシュボードに過剰表示しない。
- **テスト**：RLS/Route Handlerの403、Playwright管理者・一般会員、監査記録。

### T37 商品・仕様・画像の管理

- **目的**：管理者が8カテゴリの商品を登録・編集・公開できるようにする。
- **内容・範囲**：A02、商品・価格・仕様・用途・画像CRUD、公開時の必須条件とヤマト上限検査、公開/非公開、画像の種類・容量・寸法検査。
- **依存**：T06、T09、T36、T15。
- **受け入れ条件**：管理者のみ変更でき、仕様欠損は下書き可、公開の不備は欄下に示す。過去注文は変わらない。
- **テスト**：Zod・DB制約、RLS/Storage、Playwright登録・編集・非公開、履歴不変。

### T38 在庫調整の管理

- **目的**：実在庫と引当を安全に管理する。
- **内容・範囲**：A03、実在庫・引当・可用数表示、理由付き調整、版番号を使う競合検出、調整ログ。直接UPDATEは使わない。
- **依存**：T07、T29、T36。
- **受け入れ条件**：引当より少ない実在庫へ変更できず、競合時は最新値と再操作を案内。一般会員から更新不可。
- **テスト**：DB競合・下限、RLS、Playwright調整・失敗、監査ログ。

## T39 注文・決済状態の管理閲覧

- **目的**：要確認注文と通知障害を調査できるようにする。
- **内容・範囲**：A04、注文・試行・Webhook・引当・通知状態の必要情報のみ表示、検索、[review\\_required](#)の調査導線。決済状態の手動編集は作らない。
- **依存**：T31-T34、T36。
- **受け入れ条件**：他人の個人情報を一般会員に見せず、管理者に必要な状態・監査・原因が分かる。
- **テスト**：管理者/会員権限、Playwright注文なし・要確認、監査ID照合。

## T40 発送元・送料規則の管理

- **目的**：東京都初期設定と公式運賃の根拠を保って変更できるようにする。
- **内容・範囲**：A05、発送元、通常送料、1万円閾値、20kg規則、公式料金表・URL・確認日・版の編集と試算。変更は新しい版として保存。
- **依存**：T08、T27、T36。
- **受け入れ条件**：設定変更は新注文だけに適用され、既存注文スナップショットは不変。料金表欠損で正式見積不可。
- **テスト**：Vitest版選択・料金境界、Playwright保存/検証、監査・RLS。

## T41 SMTP設定の管理

- **目的**：管理者が送信先を環境別に安全に変更できるようにする。
- **内容・範囲**：A06、ホスト・ポート・TLS・送信元・秘密参照の更新、接続試験、旧設定復帰、監査。秘密は入力後に再表示しない。
- **依存**：T08、T20、T36。外部ゲートG-SMTP。
- **受け入れ条件**：管理者のみ更新可、秘密はDB通常表・画面・ログに平文なし。接続失敗時は旧設定で送信可能。
- **テスト**：RLS/管理API、SMTP成功/失敗、秘密非露出、監査。

## M7 品質・CI/CD・公開

### T42 異常系デモの利用者導線

- **目的**：ポートフォリオ閲覧者が指定異常系を確認できるようにする。
- **内容・範囲**：在庫切れ、注文中の在庫不足、Stripe成功/失敗、互換性不一致/不明のガイドとテスト商品・手順。管理用の内部操作は公開しない。
- **依存**：T11、T23-T35。
- **受け入れ条件**：各ケースの入口・期待表示・次の操作が分かり、実課金・実SMS・実発送を連想させない。
- **テスト**：Playwright全6ケース、ガイドと実動作の一致確認。

### T43 レスポンシブ・アクセシビリティ仕上げ

- **目的**：全画面を公開ECとして使いやすくする。
- **内容・範囲**：S01-S17/A01-A06の0-767/768-1199/1200px以上、320px、200%拡大、44px操作領域、フォーカス、読み上げ、コントラスト、管理表カード化を調整。
- **依存**：T14-T16、T21、T24、T26、T28、T33、T36-T41。
- **受け入れ条件**：主要操作に横スクロール・隠れたボタンがなく、警告は色以外でも理解できる。
- **テスト**：Playwright PC/タブレット/スマホ、axe等の自動検査とキーボード手動確認。

### T44 セキュリティ・RLS・削除の横断検証

- **目的**：公開前の個人情報・権限・秘密漏えいを防ぐ。
- **内容・範囲**：全表RLSマトリクス、管理API、Origin/Cookie/CSP、レート制限、Production認証省略拒否、秘密スキャン、30日削除・バックアップ保持条件を検証。
- **依存**：T09-T10、T17-T22、T29-T34、T36-T41。

- **受け入れ条件**：会員間隔離、管理者自己付与不可、ライブStripe鍵不在、個人情報30日削除が確認できる。問題は隠さず修正チケット化。
- **テスト**：RLS許可拒否、API侵入ケース、秘密スキャン、削除統合、手動セキュリティレビュー。

## T45 全体E2Eと性能検収

- **目的**：要件の正常系・異常系を一式で証明する。
- **内容・範囲**：Playwrightの探索→注文、Google、メール、模擬SMS、管理、競合、Webhooks、PC/タブレット/スマホをまとめ、LCP/CLS/INPを測定する。
- **依存**：T35、T42–T44。
- **受け入れ条件**：主要シナリオが再実行可能で、既知の失敗を記録し、性能目標未達は原因と改善チケットを残す。
- **テスト**：全CIテスト、Playwright、実測Web Vitals、RLS/在庫競合の再実行。

## T46 GitHub Actions・Vercel・SupabaseのCI/CD

- **目的**：レビューと環境分離を保って公開できるようにする。
- **内容・範囲**：CIにDB/RLS/Playwrightを追加、PR Preview、main Production、別Supabaseプロジェクト、マイグレーション適用ゲート、環境別変数、失敗時ロールバック手順。アプリはVercel Git連携でデプロイし、Actionsから二重デプロイしない。
- **依存**：T05、T45。外部ゲートG-GitHub/G-Vercel/G-Supabase。
- **受け入れ条件**：PreviewがProductionの個人情報・秘密・DBを共有せず、PR必須チェック失敗でmain反映できない。Productionにライブ決済鍵なし。
- **テスト**：PR Preview、mainのテストデプロイ、環境変数差分・DB適用順・ロールバック演習。

## T47 公開・運用・ポートフォリオ説明

- **目的**：採用担当者が操作できる公開デモを安全に提供する。
- **内容・範囲**：公開前チェック、規約・個人情報案内、ヤマト公式リンク、実課金なし表示、利用ガイド、監視・障害・30日削除・バックアップ手順、AI駆動開発の人間による判断とAIの役割を記録。
- **依存**：T22、T42–T46。外部ゲートG-Publication（利用者が公開先・アカウントを設定）。
- **受け入れ条件**：PC/スマホで購入体験と異常系を操作でき、実課金・実SMS・実発送なし、個人情報削除、CI/CDの証拠を確認できる。
- **テスト**：公開URLのスモーク、全主要シナリオ、監視通知、削除ジョブ、秘密・環境分離の最終確認。

# 環境構築手順

## 自作PCパーツECサイト 環境構築・接続手順（レビュー版）

版 0.9 / 作成日 2026年9月25日 / 状態 手順のみ。外部アカウント・プロジェクト・秘密は未作成、接続未実施。

実施時はAGENTS.mdとdocs/implementation-plan.mdを併読する。画面名・サービス仕様は変更され得るため、実行直前に公式資料を確認する。

### 1. 環境の対応

#### ● Local/Test

**Web:** ローカルNext.js / **DB/Auth/Storage:** ローカルSupabase CLI、テストデータ / **決済:** Stripeテスト鍵/モック / **メール/SMS:** ローカル捕捉、模擬SMS。所有端末SMS検証は別ゲート / **個人情報:** 架空情報のみ

#### ● Preview

**Web:** PRごとのVercel Preview / **DB/Auth/Storage:** 専用Supabase Previewプロジェクト。Productionデータを複製しない / **決済:** 分離したStripeテストデータ・Webhook / **メール/SMS:** 許可宛先に限定したSMTP、模擬SMS / **個人情報:** 架空情報のみ。外部閲覧を制限できる設定を検討

#### ● Production

**Web:** mainからVercel Production、ポートフォリオ一般公開 / **DB/Auth/Storage:** 専用Supabase Productionプロジェクト / **決済:** Stripeテスト鍵のみ / **メール/SMS:** 実メール送信、模擬SMS / **個人情報:** 架空情報を推奨。自由入力可、30日削除

SupabaseのPRごとのBranchingは有料プランの可能性があるため採用前提にしない。Previewは固定の別プロジェクトを使い、並行PRのDB変更が競合する場合は適用順を調整する。PreviewへProductionのDBダンプ、利用者メール、住所、注文をコピーしない。

### 2. GitHubリポジトリの初期手順（T01、T05、T46）

1. 利用者がGitHubでリポジトリの所有者・公開範囲を選び、作成・認証する。既存のdocs/、output/pdf/、AGENTS.mdを保全してローカルGitを初期化し、mainへ最初のコミットを作る。外部公開範囲の決定は利用者の操作で行う。
2. .gitignoreで.env.local、.env.\*.local、.vercel/、.next/、node\_modules/、Supabase CLIの.temp/、テスト結果を除外する。env.exampleに変数名とダミー値のみ置く。
3. PRのチェック項目をlint、TypeScript、Vitest、OpenAPI、DB/RLS、Playwright、ビルドに増やす。mainへの直接変更を制限し、利用可能なGitHubルールで必須チェックとレビューを設定する。未信頼PRに外部秘密を渡さず、pull\_request\_targetでPRコードを秘密付き実行しない。
4. GitHub Actionsの役割は検証と、承認されたDBマイグレーション適用ジョブに限定する。Vercel Git連携に任せるWebデプロイをActionsから二重に起動しない。

**利用者に提示する作業：** リポジトリ作成、所有者・公開範囲の選択、必要なGitHub/Vercel連携認証。実施前に、公開されるファイルと秘密を含めないことを確認する。

### 3. Supabaseの準備（T06–T11、T17、T46）

1. ローカル開発はDocker互換ランタイムとSupabase CLIを用意する。実装時にsupabase init、supabase startでローカル環境を開始し、supabase/migrations/とsupabase/seed.sqlをGitで管理する。ローカルスタックは外部公開しない。
2. 利用者がPreview用とProduction用の別Supabaseプロジェクトを作成し、リージョン・費用を確認する。Project Ref、Project URL、公開可能鍵、サーバー専用秘密鍵、DB接続情報を環境別に保管する。具体的な鍵の名称は実際のSupabase画面に合わせて記録する。
3. AuthのSite URLとRedirect URLsを環境別に設定する。Productionは固定の公開URL、PreviewはVercel Preview URLの許可パターン、Localはlocalhostに限定する。許可パターンは所属Vercelチーム/アカウントのドメインに絞り、無関係な外部ドメインへ広げない。
4. Google Provider、Send Email Hook、Storage、Cronは対応チケットで追加する。RLSは全表をデフォルト拒否から開始し、公開商品と本人所有データの必要操作だけ許可する。管理者権限は本人編集不可の表で管理する。
5. SMTP秘密を管理画面から変更する設計に合わせ、Supabase Vault等の保護領域の利用可否と費用をT20/T41で検証する。利用できなければ、同等の秘密保護と管理変更が両立する提案を提示し、設計変更を要するなら確認する。

## DBマイグレーションの適用手順

1. LUNAが[supabase migration new <name>](#)で追加し、SQL・制約・RLS・索引・ロールバック／復旧方針をPRに記載する。リモートDBのダッシュボードでスキーマを直接編集しない。
2. ローカルで[supabase db reset](#)を実行し、seedとDB/RLSテストを通す。**db reset --linked**をProductionに使わない。
3. Preview用Project Refを明示して[supabase link --project-ref <preview-ref>](#)、差分確認後に[supabase db push](#)を一人／一ジョブずつ実行する。PreviewでWeb・DBの統合試験を行う。
4. Productionでは後方互換な「追加→補完→切替→旧要素削除」の順に変更する。リリース前に対象Project Refとバックアップ・復旧方法を再確認し、承認されたマイグレーションをProductionへ**Web切替前**に一件ずつ適用する。初期版は手動の監督付き適用を採用し、CIによる無人自動適用は運用が安定してから別途検討する。
5. マイグレーション履歴と実DBを確認し、[main](#)反映でVercel Productionをデプロイする。失敗時はアプリを直前の互換版へ戻す。破壊的SQLの逆実行でデータを失わないよう、先に互換的な復旧手順を用意する。

## 4. Google OAuth、メール、SMS (T18–T20、T41)

**Google**：利用者がGoogle Auth PlatformでWeb OAuthクライアントを環境ごとに作成し、許可するJavaScript originとSupabase Dashboardに表示されるcallback URLを登録する。GoogleのClient ID/Secretを対応するSupabase Provider設定へ入れる。アプリからの戻り先はSupabaseのRedirect URL許可リストに合わせる。スコープは[openid email profile](#)に限定し、配送先は本サイトで入力する。設定・認証が必要になった時点で、具体的なURL一覧をLUNAが提示する。

**メール**：利用者が利用するSMTP送信先・送信元ドメイン・認証情報を決める。Supabase Auth Send Email Hookの署名秘密をVercelの環境別秘密設定へ置き、Vercelの送信処理から管理設定のSMTPへ接続する。Previewは許可宛先だけに送る。Productionは実メールを送るが、秘密は画面に再表示しない。設定前に利用料金・送信制限・ドメイン認証要件を確認する。

**SMS**：公開Productionは[mock](#)固定で、電話番号をSMS送信用に収集しない。6桁コードを当該フローのデモ通知で示し、照合は省略しない。所有端末での実SMS試験はDevelopment/Testの別設定でのみ可能にする。ゲートウェイの選定・有料利用は利用者承認後。実端末検証が終わるまで「検証済み」とポートフォリオに記載しない。

## 5. Stripeテスト決済 (T30–T32)

利用者がStripeアカウントと**テストモード**の鍵を用意する。環境別に[sk\\_test\\_\\*](#)とWebhook署名秘密を設定し、[sk\\_live\\_\\*](#)と[pk\\_live\\_\\*](#)はビルド・起動・公開前検査で拒否する。Checkoutはホスト型。カード情報をサイト側で保存しない。Webhook URLはPreviewとProductionで分け、エンドポイント秘密も共有しない。Stripeには注文ID・試行IDと確定金額のみ送り、氏名・住所・メールをメタデータに含めない。ローカルはStripe CLIまたはテストイベントを使ってWebhookを試し、署名不正・重複・逆順・再試行を検証する。

**利用者に提示する作業**：テストアカウント・テスト鍵・Webhookエンドポイントの作成／認証。ライブモードの有効化は求めない。費用が発生する外部機能が必要ななら先に見積を示す。

## 6. VercelとGitHubの接続 (T46–T47)

1. 利用者がVercelプロジェクトを作成し、対象GitHubリポジトリへのアクセスを許可する。Production Branchは[main](#)に設定する。PRでPreview、main反映でProductionが生成される構成を使う。
2. VercelのDevelopment/Preview/Productionごとに環境変数を別値で設定する。[NEXT\\_PUBLIC\\_\\*](#)だけがブラウザに露出し得る。秘密鍵をその接頭辞に置かない。変数変更後は対象環境を再デプロイして反映を確認する。
3. PreviewはPreview用Supabase・StripeテストWebhook・制限付きSMTPを指す。ProductionはProduction用Supabase・Stripe**テスト**Webhook・本番用SMTPを指す。Preview URLが複数できる場合はSupabase AuthのRedirect URL許可範囲をチームドメインへ限定する。
4. 公開前に一般閲覧者が実際の購入導線を操作できること、管理画面を非管理者が使えないこと、30日削除・監視・公式料金リンクを確認する。公開URLやドメインの最終選択は利用者が行う。

## 7. 環境変数・秘密の配置表

名称は実装チケットで[.env.example](#)と一致させる。以下は**値ではなく変数名の設計案**。秘密をMarkdown、PR、ログに貼らない。

### ● NEXT\_PUBLIC\_SITE\_URL

**Local:** localhost / **Preview:** Preview URL / **Production:** 公開URL / **公開可否**・用途: 公開可。OAuth・メール戻り先は許可URLと照合

### ● NEXT\_PUBLIC\_SUPABASE\_URL

**Local:** Local URL / **Preview:** Preview project / **Production:** Production project / **公開可否**・**用途:** 公開可

### ● NEXT\_PUBLIC\_SUPABASE\_PUBLISHABLE\_KEY

**Local:** Local / **Preview:** Preview / **Production:** Production / **公開可否**・**用途:** 公開可。ただしRLS必須。使用するSupabase鍵の名称に合わせる

### ● SUPABASE\_SERVICE\_ROLE\_KEY

**Local:** Local / **Preview:** Preview専用 / **Production:** Production専用 / **公開可否**・**用途:** サーバーのみ。RLSを迂回するため用途限定

### ● STRIPE\_SECRET\_KEY

**Local:** `sk_test_*` / **Preview:** `sk_test_*` / **Production:** `sk_test_*` / **公開可否**・**用途:** サーバーのみ。ライブ鍵拒否

### ● STRIPE\_WEBHOOK\_SECRET

**Local:** Local専用 / **Preview:** Preview専用 / **Production:** Production専用 / **公開可否**・**用途:** サーバーのみ、相互に異なる

### ● AUTH\_EMAIL\_HOOK\_SECRET

**Local:** Local専用 / **Preview:** Preview専用 / **Production:** Production専用 / **公開可否**・**用途:** サーバーのみ。Supabase Hook署名検証

### ● INTERNAL\_JOB\_SECRET

**Local:** Local専用 / **Preview:** Preview専用 / **Production:** Production専用 / **公開可否**・**用途:** サーバーのみ。Cron→Vercel内部API

### ● ANON\_CART\_SIGNING\_KEY

**Local:** Local専用 / **Preview:** Preview専用 / **Production:** Production専用 / **公開可否**・**用途:** サーバーのみ。匿名カートCookie

### ● SMS\_DELIVERY\_MODE

**Local:** `mock`／試験時のみ`real` / **Preview:** `mock` / **Production:** `mock`固定 / **公開可否**・**用途:** 公開デモの実SMSを防ぐ

### ● AUTH\_BYPASS\_ENABLED

**Local:** 必要時のみ`true` / **Preview:** `false` / **Production:** `false`固定 / **公開可否**・**用途:** Productionで`true`なら起動拒否

### ● SMTP\_ALLOWED\_RECIPIENTS

**Local:** テスト宛先 / **Preview:** 許可宛先ののみ / **Production:** 運用方針に従う / **公開可否**・**用途:** 宛先制限。SMTP資格情報はVault等の保護領域

### ● Google Client Secret

**Local:** Local Provider / **Preview:** Preview Supabase / **Production:** Production Supabase / **公開可否**・**用途:** Supabase側のProvider設定。アプリDB/ブラウザに保存しない

### ● Supabase CLIのAccess Token/DB資格情報

**Local:** 必要時のみ / **Preview:** 適用作業のみ / **Production:** 承認された適用作業のみ / **公開可否**・**用途:** GitHub環境秘密または利用者の安全なローカル保管。PR検証に渡さない

## 8. 外部サービスの利用者作業ゲート

### ● G-GitHub

**発生時点:** T01/T05/T46 / **利用者に提示する具体的な作業:** リポジトリ作成、所有者・公開範囲・連携許可、利用可能な保護ルールの確認 / **未完了時にできること:** ローカルGitとCI定義の作成

### ● G-Supabase

**発生時点:** T17/T32/T46 / **利用者に提示する具体的な作業:** Preview/Production別プロジェクト作成、リージョン・費用確認、鍵とProject Refの安全な登録 / **未完了時にできること:** ローカルDB、RLS、マイグレーション試験

### ● G-Google

**発生時点:** T18 / **利用者に提示する具体的な作業:** OAuthクライアント作成、環境別origin/callback URL登録、Supabase Provider設定 / **未完了時にできること:** callbackコードと模擬試験

### ● G-SMTP

**発生時点:** T20/T41 / **利用者に提示する具体的な作業:** SMTP送信先・送信元ドメイン・認証、料金と送信制限確認 / **未完了時にできること:** モック送信・Hook署名・UI試験

### ● G-Stripe

**発生時点:** T30-T32 / **利用者に提示する具体的な作業:** テストアカウント、テスト鍵、環境別Webhook登録 / **未完了時にできること:** SDKモックと状態機械試験

### ● G-Vercel

**発生時点:** T46 / **利用者に提示する具体的な作業:** プロジェクト作成、GitHub連携、環境変数、Preview/Production設定 / **未完了時にできること:** ローカルビルドとActions検証

## ● G-Publication

**発生時点:** T47 / **利用者に提示する具体的な作業:** 公開URL/ドメイン・公開範囲の最終選択 / **未完了時にできること:** Previewで最終スモーク

有料プラン、課金、契約、本人認証が必要になったら、LUNAはその時点で「何を作るか／なぜ必要か／費用見込み／無料代替／設定後の確認方法」を提示する。利用者の操作・承認が届くまで外部接続の完了を主張しない。

## 9. リリース前の確認

- PreviewとProductionでSupabase Project Ref、Stripeテスト鍵・Webhook秘密、SMTP送信先、Hook秘密、Cron秘密が異なる。
- [main](#)の必須CIが成功し、Productionに認証省略とライブStripe鍵が存在しない。
- DBマイグレーション履歴・RLS・Storage・バックアップ復元を確認し、個人情報を含むバックアップにも30日方針を適用できる。
- メール確認・Google・模擬SMS・パスワード再設定、商品探索、構成、不一致でも購入、在庫競合、Stripe成功/失敗、注文履歴、管理者拒否が通る。
- サイトに実販売・実課金・実発送なし、架空住所の推奨、30日削除、ヤマト運輸の公式情報リンクを表示する。
- 障害時の連絡先、Webhook滞留、在庫引当期限、メール失敗、削除ジョブ失敗を監視できる。

## 10. 公式資料

- [Vercel Git連携](#)、[環境変数](#)
- [Supabase CLI](#)、[DBマイグレーション](#)、[環境管理](#)、[Auth Redirect URLs](#)
- [Supabase Google OAuth](#)、[Send Email Hook](#)
- [GitHub Actions Deployment environments](#)
- [Stripe Checkoutテスト](#)、[Webhook](#)

# AGENTS.md

## 自作PCパーツECサイト 実装担当AI向けルール

このファイルは、LUNAを含む実装担当AIが承認された1チケットずつ作業するときのガードレールである。現段階では製品実装を始めない。本ファイルの追加だけで実装開始の許可とはみなさない。

### 1. 正本と判断順位

1. ユーザーの最新の明示指示。
2. [output/pdf/自作PCパーツECサイト\\_要件定義書\\_レビュー版.pdf](#) と、それ以後にユーザーが明示承認した送料・個人情報の決定（[docs/detailed-design-review.md](#)に反映済み）。
3. [output/pdf/自作PCパーツECサイト\\_基本設計書\\_レビュー版.pdf](#)。
4. [output/pdf/自作PCパーツECサイト\\_詳細設計書\\_レビュー版.pdf](#)、編集用の[docs/detailed-design-review.md](#)。
5. [docs/implementation-plan.md](#)、[docs/implementation-tickets.md](#)、[docs/environment-setup.md](#)と現在割り当てられたチケット。

上位資料と下位資料が矛盾する、詳細設計に複数案が残る、外部サービスの制約で設計どおりにできない場合は、推測で実装しない。根拠の箇所、影響、選択肢を報告し、仕様変更が必要なら利用者の判断を待つ。通常のライブラリ内部の選択は、設計の範囲内で理由を記録して決めてよい。

### 2. チケット作業の約束

- 1回の作業で1チケットを完了する。目的、範囲、依存、受け入れ条件、必要テストを先に読む。依存チケットの成果を確認してから着手する。
- チケット外の機能、UI、DB、RLS、設定を勝手に変更しない。不可避の小さな関連変更は理由と影響を明記する。追加仕様や設計変更は別チケットとして提案する。
- 作業前に対象ファイルと既存変更を確認する。既存の利用者変更を上書きしない。ソース、マイグレーション、テスト、設計の差分をレビュー可能な単位にする。
- 完了報告に「変更点、設計根拠、実行したテストと結果、未解決の問題、外部設定の要否」を記載する。テストが実行できなければ理由と代替検証を記載し、合格扱いにしない。
- 受け入れ条件を満たせないときは完了扱いにしない。テストを通すために要件・設計・テストを弱めたり、異常系を削除したりしない。

### 3. 固定した技術と責務

Next.js App Router、React、TypeScript、CSS Modules、Zod、Supabase Postgres/Auth/Storage/Cron、[@supabase/ssr](#)、Stripe Checkout **テスト環境**、Vitest、Playwright、GitHub Actions、Vercel Git連携を使う。ライブ決済を導入しない。外部商品API、ゲスト注文、利用者向け取り置き、構成保存は初期版に加えない。

予定ディレクトリ（初期化チケットで作成）：

- [src/app/\(shop\)/](#)  
責務: 公開ECと会員画面のルート・画面
- [src/app/admin/](#)  
責務: 管理画面。画面の非表示だけで権限を守らない
- [src/app/api/](#)  
責務: Route Handler、Webhook、Auth Hook、内部ジョブ入口
- [src/components/](#)、[src/styles/](#)  
責務: 再利用UI、CSS Modules、デザイントークン
- [src/features/](#)  
責務: 商品、互換性、カート、注文、決済等の機能別UI・操作
- [src/server/](#)  
責務: サーバー専用データ取得・業務処理・外部サービスアダプタ

- [src/lib/](#)

責務: 共有型、Zodスキーマ、金額・状態の純粋関数。秘密に依存しない

- [supabase/migrations/](#)、[supabase/seed.sql](#)

責務: 版管理されたSQLと開発・テスト専用データ

- [tests/](#)、[docs/api/](#)、[docs/wireframes/](#)

責務: Vitest/Playwright/RLS等、OpenAPI、画面ワイヤー

Server Componentは表示用取得をデータ層から行う。価格・送料・在庫・権限・決済結果はブラウザで確定しない。変更操作は認証・検証したサーバー経路に集め、在庫・注文はDB内の原子的処理で更新する。ドメイン計算を画面とAPIで二重実装しない。

## 4. DB・RLS・認証・秘密

- 全公開スキーマの表でRLSを有効化し、[anon](#)と[authenticated](#)には必要最小限の権限のみ付与する。所有者条件を表だけでなく関連明細にも適用する。下書き商品、他人の住所・注文、管理データを公開しない。
- 管理権限は[admin\\_memberships](#)で判定し、一般会員が自己付与できない。画面とAPIとDBで検証する。サービスロール鍵は信頼できるサーバー専用で、ブラウザ・[NEXT\\_PUBLIC\\_\\*](#)・ログ・テスト出力に出さない。
- [auth.users](#)はSupabase Authが管理する。メール確認、Google OAuth、模擬SMS、パスワード再設定、開発・テスト限定バイパスの条件を設計どおりに守る。Productionで認証省略を起動できないことを検証する。
- Stripeはテスト鍵だけを使用し、Webhook署名を検証する。戻りURLだけで注文を成功にしない。イベント重複、逆順、再試行、引当期限、遅延成功を処理する。
- SMTP認証情報、Hook秘密、Stripe鍵、Supabaseサービスロール鍵、Googleクライアント秘密をGit、画面、ログへ出さない。秘密は環境別に管理し、SMTPの管理画面には平文を再表示しない。
- SQL変更は必ず[supabase/migrations/](#)へ追加し、RLSポリシーSQLと許可・拒否テストを同じチケットまたは依存チケットに含める。リモートDBをダッシュボードで直接変更して履歴をずらさない。Productionを[db reset](#)しない。
- 住所・注文・会員情報は設計の30日削除方針を守る。Stripeへ個人情報情報を渡さず、削除と監査で秘密・住所本文を残さない。

## 5. 金額・在庫・UI

税込円の整数で計算する。通常送料は全国一律940円、税込商品代金10,000円以上で通常送料0円。20kg以上の商品は商品ごとにヤマト運輸公式運賃を加算し、離島という理由だけでは加算しない。税率10%、税率ごとに注文単位で内税額を一回切り捨てる。注文時の価格・住所・商品・送料規則をスナップショットで保存する。カート送料は概算、注文確認は正式額。決済中だけ引当し、失敗・期限切れで解放する。

色は主背景[#F7F9FC](#)、サーフェス[#FFFFFF](#)、本文[#172033](#)、主操作[#155EEF](#)、注意[#9A5B00](#)、危険[#B42318](#)、成功[#067647](#)を基準とする。スマートフォン0-767px、タブレット768-1199px、PC1200px以上。320px・200%拡大、キーボード操作、WCAG 2.2 AA、44px以上の操作領域を検証する。互換性不一致でもカート・購入を許し、警告と適合商品リンクを示す。繰り返しモーダルを出さない。異常系は原因と次の操作を表示する。

## 6. テストと外部作業の停止条件

各チケットに記載されたVitest、DB統合、RLS、Playwright、手動確認を実行する。特に在庫競合、金額境界、Webhook重複・失敗、他人データ拒否、レスポンスを省略しない。CI失敗を無視して先へ進めない。

GitHub、Vercel、Supabase、Google、Stripe、SMTP、SMS等で利用者によるアカウント作成・接続・認証・有料契約が必要なときは、必要な操作、保存する情報、費用の有無を具体的に提示する。本人に代わって契約・課金・認証しない。設計範囲のローカル作業は進めてよいが、外部設定が必要な受け入れ条件を未確認のまま完了にしない。